



ROAD TO HALL OF FAME

Bypass con Byte Nulo en la Extensión ´

Actividad 12 · Reporte de laboratorio

Ingeniería en Tecnologías de la Información

Universidad Politécnica de San Luis Potosí

Fundamentos de Ciberseguridad

Mtro. Servando López Contreras

Juan Francisco Ortega Jiménez · Matrícula 184918

25 de septiembre de 2026



Road to Hall of Fame — Bypass con Byte Nulo en la Extensión

1. Datos generales del laboratorio

Nombre del laboratorio	File path traversal, validation of file extension with null byte bypass
Nivel	Practitioner
Tipo de explotación	Path Traversal / Directory Traversal — bypass de validación de extensión mediante byte nulo
Objetivo del laboratorio	Obtener el contenido del archivo /etc/passwd explotando el parámetro "filename", evadiendo una validación que exige que la ruta termine con una extensión de archivo permitida.
URL del laboratorio	https://portswigger.net/web-security/file-path-traversal/lab-validate-file-extension-null-byte-bypass

2. Explicación técnica de la vulnerabilidad

Este laboratorio agrega una capa de validación distinta a las anteriores: en lugar de revisar el inicio de la ruta, la aplicación valida que el valor recibido en el parámetro filename termine ("ends with") con una extensión de archivo permitida, como .jpg. Esto busca asegurar que, sin importar qué ruta se solicite, el resultado final sea siempre un archivo de imagen.

Sin embargo, muchas funciones de manejo de archivos en el sistema operativo y en ciertos lenguajes de programación interpretan el carácter nulo (byte 0x00, representado en una URL como %00) como el fin de una cadena de texto. Es decir, aunque la aplicación reciba una cadena más larga, el sistema operativo puede detener su lectura justo en ese byte nulo, ignorando por completo cualquier carácter posterior.

Esto permite construir un payload que combina una secuencia de traversal real, seguida de un byte nulo y, después de este, una extensión de archivo falsa que solo existe para engañar a la validación de la aplicación (que sí revisa la cadena completa y ve que "termina" en .jpg). El sistema operativo, al procesar la ruta, se detiene en el byte nulo y nunca llega a leer esa extensión

falsa, resolviendo la ruta real hacia el archivo de traversal. Esta vulnerabilidad también corresponde a OWASP Top 10 – A01:2021 Broken Access Control.

3. Procedimiento paso a paso

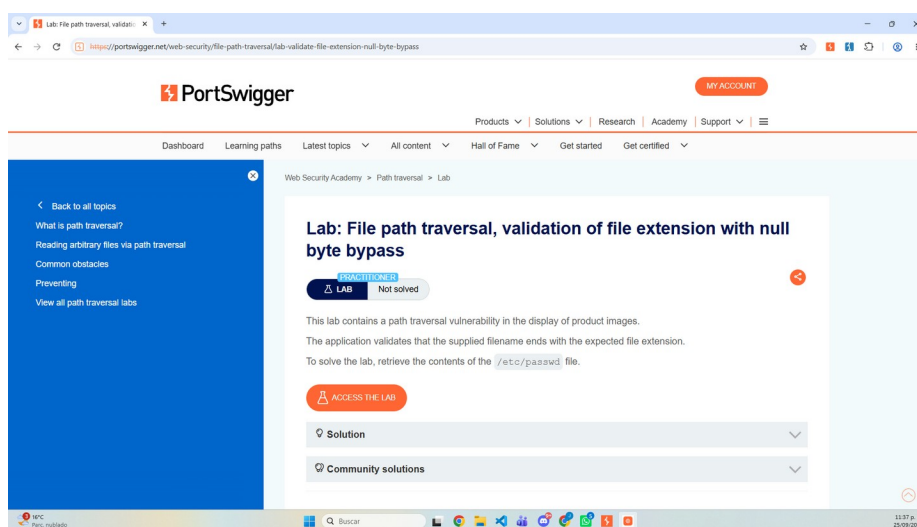
- Abrir Burp Suite Community Edition y crear un "Temporary project in memory" con la configuración por defecto.
- Acceder a la URL del laboratorio e iniciar sesión con la cuenta de PortSwigger; dar clic en "Access the lab".
- En la tienda ("We Like To Shop"), navegar entre los productos para generar tráfico hacia el servidor.
- Ajustar el filtro de HTTP history en Burp: marcar la casilla "Images" en "Filter by MIME type" y dejar vacío el campo "Hide" en "Filter by file extension", ya que el filtro por defecto oculta las peticiones de imagen.
- Con el filtro corregido, localizar en HTTP history una petición GET /image?filename=NOMBRE.jpg.
- Seleccionar esa petición, clic derecho → "Send to Repeater", e ir a la pestaña Repeater.
- En Repeater, reemplazar el valor del parámetro filename por el payload con byte nulo: ../../../../etc/passwd%00.jpg, donde la extensión .jpg después de %00 solo sirve para engañar a la validación de la aplicación.
- Enviar la petición (Send / Ctrl+Enter) y revisar el panel de respuesta: el servidor devuelve "HTTP/2 200 OK" con el contenido completo de /etc/passwd.
- Regresar a la pestaña del laboratorio en PortSwigger, refrescar la página y confirmar que el estatus cambia de "Not solved" a "Solved".

4. Evidencias fotográficas del proceso

A continuación se documenta, en orden cronológico, cada paso realizado durante la explotación del laboratorio, con su captura de pantalla correspondiente.

4.1 Página del laboratorio (estado inicial)

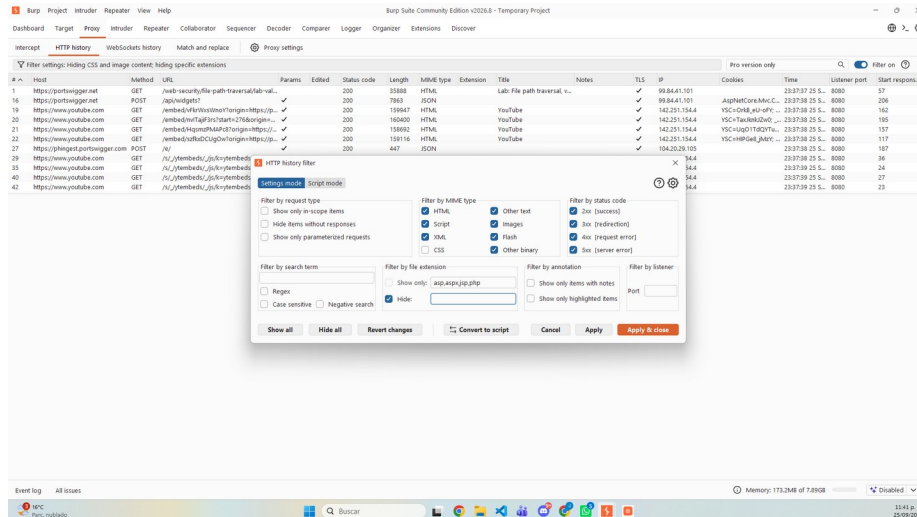
Página oficial del laboratorio en PortSwigger, mostrando el nivel "Practitioner", el estado inicial "Not solved" y la descripción del reto: la aplicación valida que el filename recibido termine con la extensión de archivo esperada.



4.2 Generación de tráfico en la tienda

Se accedió a la tienda ("We Like To Shop") y se navegó entre los productos para generar peticiones GET /image?filename= hacia el servidor, necesarias para poder interceptarlas en Burp.

Se abrió el diálogo de filtros de HTTP history y se confirmó que la casilla "Images" en "Filter by MIME type" estuviera marcada, con el campo "Hide" en "Filter by file extension" vacío, para poder visualizar las peticiones a archivos de imagen.



Con el filtro corregido, las peticiones GET /image?filename=XX.jpg quedaron visibles en HTTP history. Se seleccionó una de ellas (filename=8.jpg) para continuar con el ataque.

The screenshot shows the Burp Suite interface with the HTTP history tab active. A list of intercepted requests is shown, with the selected request (index 132) highlighted. The request is a GET to `https://oas04703d68b00743.../image?filename=27.jpg`. The right-hand pane shows the 'Response' tab with the HTTP 200 OK status and the full response body content.

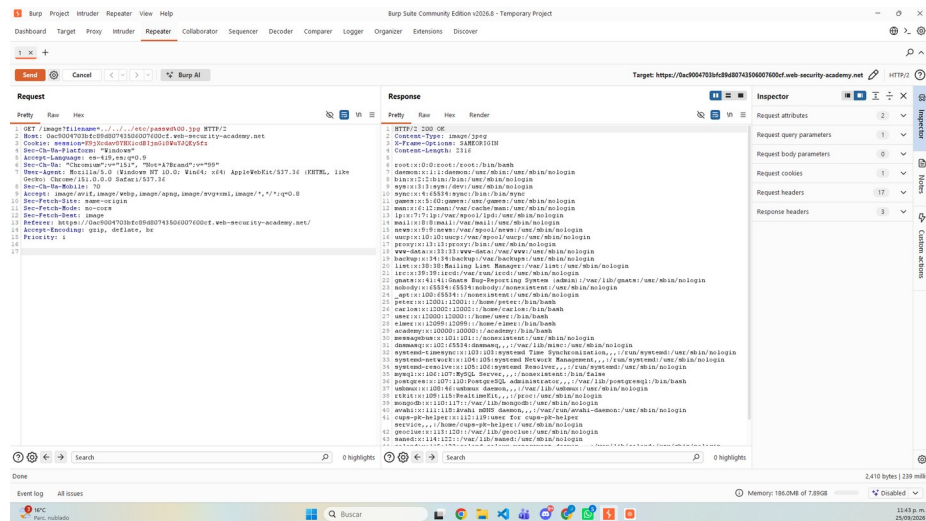
4.5 Envío de la petición a Repeater

Se hizo clic derecho sobre la petición seleccionada y se eligió la opción "Send to Repeater" del menú contextual, para poder modificar y reenviar la petición manualmente.

The screenshot shows the Burp Suite interface with the HTTP history tab active. A right-click context menu is open over the selected request (index 132). The menu options include 'Send to Repeater', 'Send to Sequencer', 'Send to Comparer', 'Send to Site Map', 'Send to Site Map (request)', 'Open response in browser', 'Record an issue (this version only)', 'Engagement tools (this version only)', 'Add notes', 'Highlight', 'Delete item', 'Show new history window', 'Copy URL', 'Copy body in response', 'Save item', and 'Proxy history documentation'. The 'Send to Repeater' option is highlighted.

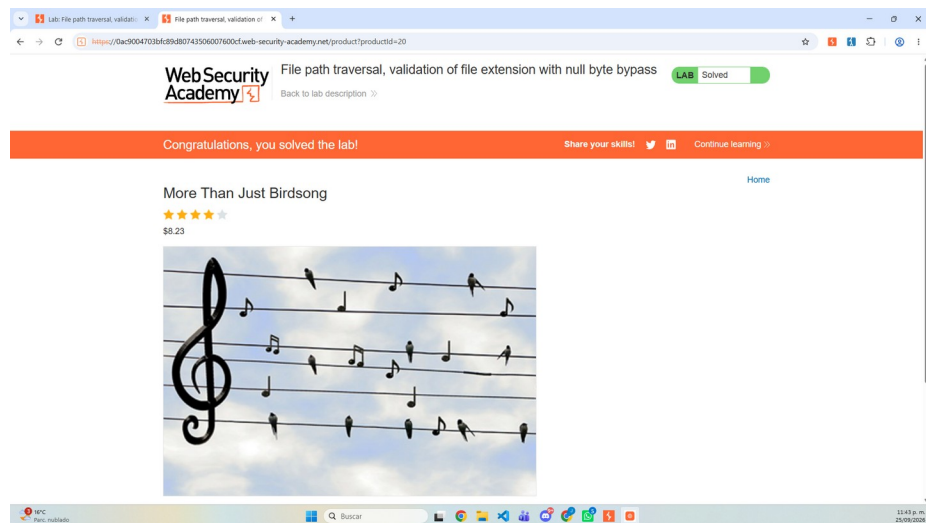
4.6 Payload con byte nulo y respuesta vulnerable

Se reemplazó el valor del parámetro filename por `../../../../etc/passwd%00.jpg`. Al enviar la petición, el servidor respondió "HTTP/2 200 OK", devolviendo el contenido completo del archivo `/etc/passwd`, confirmando que la validación de extensión fue evadida gracias al byte nulo.



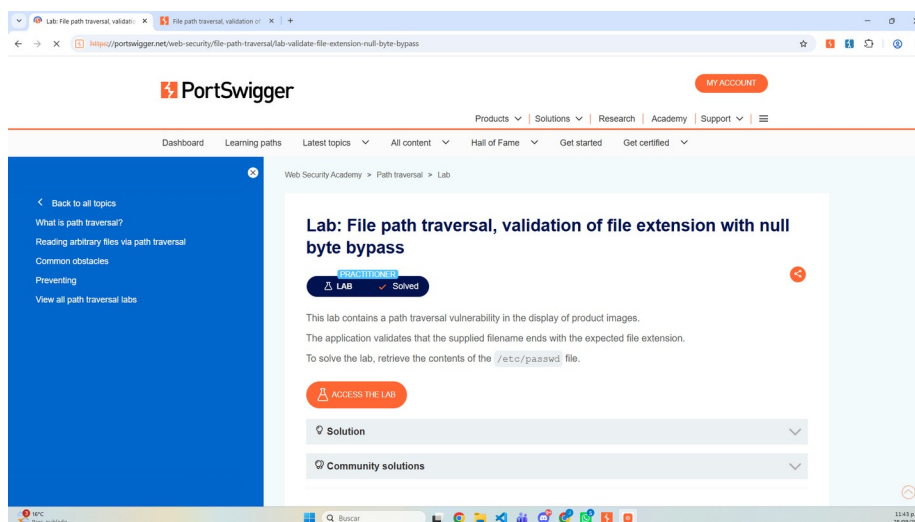
4.7 Confirmación en la tienda

Al regresar a la página del producto y refrescarla, se mostró el banner naranja "Congratulations, you solved the lab!" junto con el indicador de estado en verde "Solved".



4.8 Confirmación "Lab Solved" en la página oficial

La página oficial del laboratorio en PortSwigger confirmó el cambio de estado de "Not solved" a "Solved", validando que el objetivo de recuperar el contenido de /etc/passwd se cumplió exitosamente.



5. Explicación del payload

Payload utilizado: ../../../../etc/passwd%00.jpg

- La primera parte del payload, ../../../../etc/passwd, es la secuencia de traversal estándar: tres saltos de directorio que llevan desde la carpeta de imágenes hasta la raíz del sistema de archivos, seguidos de la ruta hacia el archivo objetivo.
- El carácter %00 representa, en codificación URL, el byte nulo (valor 0x00 en ASCII), que tradicionalmente se utiliza como terminador de cadenas en muchos lenguajes de bajo nivel y en funciones del sistema operativo para manejo de archivos.
- La extensión .jpg que se agrega después del byte nulo nunca es procesada por el sistema operativo, ya que este detiene la lectura de la ruta exactamente en el byte nulo. Sin embargo, esa misma extensión sí es visible para la validación de la aplicación, la cual revisa la cadena completa (incluyendo lo que viene después del %00) y confirma que "termina" en .jpg, dejando pasar la petición.
- Esta discrepancia entre lo que la aplicación valida (la cadena completa) y lo que el sistema operativo realmente interpreta (la cadena truncada en el byte nulo) es la base

de este tipo de bypass, característico de aplicaciones construidas sobre tecnologías más antiguas o con manejo de cadenas en lenguajes de bajo nivel.

6. Incidencias durante la práctica

- Filtro de contenido en Burp: al iniciar sesión de trabajo, fue necesario confirmar que el filtro de HTTP history mostrara imágenes ("Images" marcado en "Filter by MIME type"), repitiendo el ajuste realizado en actividades anteriores.
- Ninguna otra incidencia relevante: el payload `../../../../etc/passwd%00.jpg` funcionó correctamente desde el primer intento, obteniendo una respuesta "200 OK" con el contenido de `/etc/passwd`.

7. Mitigación recomendada

- Actualizar el entorno de ejecución (lenguaje, framework o librerías) a versiones modernas donde las funciones de manejo de archivos ya no interpreten el byte nulo como terminador de cadena de forma insegura.
- No basar la validación de un archivo únicamente en que su nombre termine con una extensión específica; en su lugar, verificar el tipo real del contenido (por ejemplo, mediante la revisión de los primeros bytes o "magic numbers" del archivo).
- Canonicalizar la ruta completa (resolver la ruta real, por ejemplo con funciones como `realpath()`) antes de aplicar cualquier validación, y verificar que el resultado final se encuentre dentro del directorio permitido.
- Rechazar de forma explícita cualquier entrada que contenga bytes nulos o caracteres de control antes de procesar la ruta, independientemente del framework o lenguaje utilizado.

- Utilizar identificadores indirectos (por ejemplo, un ID numérico mapeado internamente a la ruta real del archivo) en lugar de construir la ruta a partir de datos proporcionados por el usuario.

8. Conclusión

Este laboratorio permitió comprender cómo una discrepancia entre la forma en que una aplicación valida una cadena de texto y la forma en que el sistema operativo subyacente la interpreta puede abrir una vulnerabilidad crítica. El byte nulo, al truncar la lectura de la ruta antes de que la aplicación termine de "verla", permite adjuntar una extensión falsa que satisface la validación sin afectar el destino real del archivo, reforzando la importancia de validar el contenido real de un archivo y no únicamente el texto de su nombre.

Referencias

PortSwigger. (2026). File path traversal, validation of file extension with null byte bypass

[Laboratorio interactivo]. Web Security Academy.

<https://portswigger.net/web-security/file-path-traversal/lab-validate-file-extension-null-byte-bypass>

OWASP Foundation. (2021). OWASP Top 10:2021 – A01 Broken Access Control.

https://owasp.org/Top10/A01_2021-Broken_Access_Control/